

Confidentiality and Privacy Controls

LEARNING OBJECTIVES

- 1 Describe the controls that can be used to protect the confidentiality of an organization's information and the privacy of personal information it collects from customers, suppliers, and employees.
- 2 Discuss how the Privacy Management Framework developed jointly by the AICPA and the Chartered Institute of Management Accountants provides guidance in developing a comprehensive approach to protecting privacy that satisfies the requirements of privacy regulations such as the EU's General Data Privacy Regulation (GDPR) and California's Consumer Privacy Act (CCPA).
- 3 Discuss how different types of encryption systems work and explain the difference between encryption and hashing.
- 4 Explain how to create a digital signature and how it provides a means to create legally enforceable contracts.
- 5 Discuss how blockchain works.

INTEGRATIVE CASE

Northwest Industries

Jason Sun was preparing for his meeting with the Northwest Industries' chief information security officer (CISO). Although Jason was satisfied that Northwest Industries' computer security policies and procedures provided the company with adequate protection against intrusions, he was concerned about other aspects of systems reliability. In particular, he wanted to learn what Northwest Industries was doing to address the following issues:

1. Protecting the confidentiality of sensitive corporate information, such as marketing plans and trade secrets.
2. Protecting the privacy of personal information it collected from customers, employees, suppliers, and business partners.

Jason planned to use his interview with the CISO to obtain a general understanding of the company's information systems controls to protect confidentiality and privacy. He then planned to follow up by collecting evidence about the effectiveness of those controls and whether Northwest's policies and procedures were compliant with new privacy regulations.



Introduction

Chapter 11 discussed information security, which is the fundamental principle of systems reliability. This chapter covers two other important principles of reliable systems in the Trust Services Framework: (1) preserving the confidentiality of an organization's intellectual property and (2) protecting the privacy of personal information it collects from customers, employees, suppliers, and business partners. We discuss the topic of encryption in detail because it is a critical tool for protecting both confidentiality and privacy. We also discuss hashing because it plays an important role in creating both digital signatures and blockchains.

Protecting Confidentiality and Privacy

Organizations possess a myriad of sensitive information, including strategic plans, trade secrets, cost information, legal documents, and process improvements. This intellectual property often is crucial to the organization's long-run competitive advantage and success. Consequently, preserving the confidentiality of the organization's intellectual property, and similar information shared with it by its business partners, has long been recognized as a basic objective of information security. Organizations also need to protect the privacy of personal information they collect from suppliers, customers, and employees. The objectives for confidentiality and privacy are the same: protect sensitive information from unauthorized access and disclosure. Consequently, as Figure 12-1 shows, the same four basic actions must be taken to protect both confidentiality and privacy: (1) identify and classify the information to be protected, (2) encrypt the information, (3) control access to the information, and (4) train employees to properly handle the information.

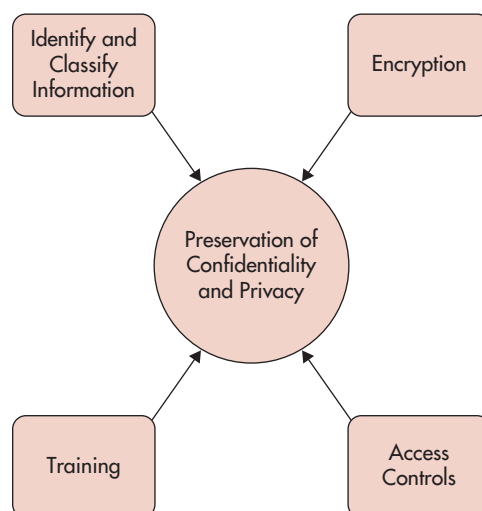


FIGURE 12-1
Components
of Protecting
Confidentiality and
Privacy

IDENTIFY AND CLASSIFY INFORMATION TO BE PROTECTED

The first step to protect confidentiality and privacy is to identify where such information resides and who has access to it. This sounds easy, but undertaking a thorough inventory of every digital and paper store of information is both time-consuming and costly because it involves examining more than just the contents of the organization's financial systems. For example, manufacturing firms typically employ large-scale factory automation. Those systems contain instructions that may provide significant cost advantages or product quality enhancements over those of competitors and therefore must be protected from unauthorized disclosure or tampering.

After the information that needs to be protected has been identified, the next step is to classify the information in terms of its value to the organization. Control Objectives for Information and Related Technology (COBIT) 2019 management practice APO01.07 points out that classification is the responsibility of information owners, not information security professionals, because only the former understand how the information is used. This classification process is critical because you must know the value of information in order to assess the relative costs and benefits of alternative solutions to protecting it.

PROTECTING SENSITIVE INFORMATION WITH ENCRYPTION

Encryption (to be discussed later in this chapter) is an extremely important and effective tool to protect confidentiality and privacy. It is the only way to protect information in transit over the Internet. It is also a necessary part of defense-in-depth to protect information stored on websites or in a public cloud. For example, many accounting firms have created secure portals that they use to share sensitive audit, tax, or consulting information with clients. Encrypting the client's data that is stored on the portal provides an additional layer of protection in the event of unauthorized access to the portal. Similarly, encrypting information stored in a public cloud protects it from unauthorized access by employees of the cloud service provider or by anyone else who is using that same cloud. Encrypting customers' personal information not only protects it from unauthorized disclosure, but also can save organizations money. Many states have passed data breach notification laws that require organizations to notify customers after any event, such as the loss or theft of a laptop or portable media device, that may have resulted in the unauthorized disclosure of customer personal information. This can be expensive for businesses that have hundreds of thousands or millions of customers. The costly notification requirement is usually waived, however, if the lost or stolen customer information was encrypted.

Encryption, however, is not a panacea. Encryption only protects information while it is stored or being transmitted, not during processing, because information must be decrypted in order to be processed. Thus, the employees (such as the database administrator and data analysts) who run the programs that use sensitive information can potentially view confidential information. Similarly, full disk encryption of laptops only protects the information until someone successfully authenticates and logs on to the laptop. Encryption also does not protect information when it is displayed on a monitor or printed in a report. Consequently, protecting confidentiality and privacy requires application of the principle of defense-in-depth by supplementing encryption with the other two components in Figure 12-1: access controls and training.

CONTROLLING ACCESS TO SENSITIVE INFORMATION

Chapter 11 discussed how organizations use authentication and authorization controls to restrict access to information systems that contain sensitive information. Authentication and authorization controls, however, are not sufficient to protect confidentiality and privacy because they only control initial access to sensitive information that is stored digitally. Organizations need to protect sensitive information throughout its entire life cycle, including distribution and disposal, regardless of whether it is stored digitally or physically. Thus, the basic authentication and authorization controls discussed in **Chapter 11** need to be supplemented with additional digital and physical access controls.

Information rights management (IRM) software provides an additional layer of protection to sensitive information stored in digital format, offering the capability not only to limit access to specific files or documents, but also to specify the actions (read, copy, print, download to USB devices, etc.) that individuals granted access to that resource can perform. Some IRM software even has the capability to limit those privileges to a specific period of time and to remotely erase protected files. Either the creator of the information or the person responsible for managing it must assign the access rights. To access an IRM-protected resource, a person must first authenticate to the IRM server, which then downloads code to that person's computer that enables access to the information.

Today, organizations constantly exchange information with their business partners and customers. Therefore, protecting confidentiality also requires controls over outbound communications. One tool for accomplishing that is **data loss prevention (DLP)** software, which works like antivirus programs in reverse, blocking outgoing messages (whether e-mail, instant messaging, or other means) that contain key words or phrases associated with the intellectual property or other sensitive data the organization wants to protect. DLP software is a preventive control. It can and should be supplemented by embedding code called a **digital watermark** in documents. The digital watermark is a detective control that enables an organization to identify confidential information that has been disclosed. When an organization discovers documents containing its digital watermark on the Internet, it has evidence that the preventive controls designed to protect its sensitive information have failed. It should then investigate how the compromise occurred and take appropriate corrective action. It is especially important to prevent programmers from having access to personal information such as credit card numbers, telephone numbers, and Social Security numbers. In developing new applications, programmers often have to use "realistic" data to test the new system. It is tempting and easy to provide them with a copy of the data in the organization's transaction processing system. Doing so, however, gives programmers access to customers' personal information. To protect privacy, organizations should run **data masking** programs that replace such personal information with fake values (e.g., replace a real Social Security number with a different set of numbers that have the same characteristics, such as 123-45-6789) before sending that data to the program development and testing system. The fake data are called *tokens*; hence, data masking is often referred to as **tokenization**.

Organizations also need to train employees on how to manage and protect personal information collected from customers. This is especially important for medical and financial information. Obviously, intentional misuse of such information can have serious negative economic consequences, including significant declines in stock prices. Unintentional disclosure of such personal information can also create costly problems, however. For example, someone denied health or life insurance because of improper disclosure of personal information is likely to sue the organization that was supposed to restrict access to that data.

The basic physical access controls discussed in **Chapter 11** are designed to prevent someone with unsupervised access from quickly downloading and copying gigabytes of confidential information onto a USB drive, an iPad, a cell phone, or other portable device. It is especially important to restrict access to rooms that contain printers, digital copiers, and fax machines because such devices typically possess large amounts of RAM, which may store any confidential information that was printed. In addition, laptops and workstations should run password-protected screen savers automatically after a few minutes of inactivity to prevent unauthorized viewing of sensitive information. Screen protection devices that limit the distance and angle from which information on a laptop or workstation monitor can be seen provide additional means to safeguard sensitive information, particularly in areas to which visitors have access.

COBIT 2019 management practice DSS05.06 discusses the need to also control physical access to sensitive information stored in physical documents. It also stresses the importance of proper *disposal* of sensitive information. Printed reports and microfilm containing sensitive information should be shredded before being thrown out. Proper disposal of computer media requires use of special software designed to "wipe" the media clean by repeatedly overwriting the disk or drive with random patterns of data. Using built-in operating system commands

information rights management (IRM) - Software that offers the capability not only to limit access to specific files or documents, but also to specify the actions (read, copy, print, download, etc.) that individuals granted access to that resource can perform. Some IRM software even has the capability to limit access privileges to a specific period of time and to remotely erase protected files.

data loss prevention (DLP) - Software that works like antivirus programs in reverse, blocking outgoing messages (e-mail, instant messages, etc.) that contain key words or phrases associated with intellectual property or other sensitive data the organization wants to protect.

digital watermark - Code embedded in documents that enables an organization to identify confidential information that has been disclosed.

data masking - Protecting privacy by replacing sensitive personal information with fake data. Also called *tokenization*.

tokenization - Another word for data masking.

to delete that information is insufficient because many utility programs exist that can recover such deleted files. Indeed, there are numerous stories about people who have purchased used computers, cell phones, digital copy machines, and other devices and discover sensitive information on those devices the previous owner thought had been deleted. Probably the safest alternative is to physically destroy (e.g., by incineration) magnetic and optical media that have been used to store extremely sensitive data.

Access controls designed to protect confidentiality and privacy must be continuously reviewed and modified to respond to new threats created by technological advances. For example, until recently wiretaps were the only serious threat to the confidentiality of telephone conversations, and the difficulty of setting them up meant the risk of that threat was relatively low. Voice over Internet Protocol (VoIP) technology, however, routes telephone conversations as packets over the Internet. This means VoIP telephone conversations are as vulnerable to interception as any other information sent over the Internet. Therefore, VoIP conversations about sensitive topics should be encrypted.

Virtualization and cloud computing also affect the risk of unauthorized access to sensitive information. An important control in virtual environments, including internally managed “private” clouds, is to use virtual firewalls to restrict access between different virtual machines that coexist on the same physical server. In addition, virtual machines that store highly sensitive data should not be hosted on the same physical server with virtual machines accessible via the Internet because of the risk that a skilled attacker might be able to break out of the latter and compromise the former. With public clouds, the data is stored elsewhere, and access occurs over the Internet via browsers. Therefore, all communication between users and the cloud must be encrypted. Moreover, highly sensitive data probably should not be stored in a public cloud because of lack of control over where that information is actually stored and because of the risk of unauthorized access by other cloud customers, who may include competitors, or even by employees of the cloud provider.

TRAINING

Training is arguably the most important control for protecting confidentiality and privacy. Employees need to know what information they can share with outsiders and what information needs to be protected. For example, employees often do not realize the importance of information they possess, such as time-saving steps or undocumented features they have discovered when using a particular software program. Therefore, it is important for management to inform employees who will attend external training courses, trade shows, or conferences whether they can discuss such information or whether it should be protected because it provides the company a cost savings or quality improvement advantage over its competitors.

Employees also need to be taught how to protect sensitive data. Training should cover such topics as how to use encryption software and the importance of always logging out of applications and using a password-protected screen saver before leaving their laptop or workstation unattended to prevent other employees from obtaining unauthorized access to that information. Employees also need to know how to code reports they create to reflect the importance of the information contained therein so that other employees will know how to handle those reports. They also need to be taught not to leave reports containing sensitive information in plain view on their desks. Training is particularly important concerning the proper use of e-mail, instant messaging (chat), and blogs because it is impossible to control the subsequent distribution of information once it has been sent or posted through any of those methods. For example, it is important to teach employees not to routinely use the “reply all” option with e-mail because doing so may disclose sensitive information to people who should not see it.

With proper training, employees can play an important role in protecting the confidentiality of an organization’s information and the privacy of sensitive personal information about suppliers, customers, and employees. For example, if employees understand their organization’s data classification scheme, they may recognize situations in which sensitive information has not been properly protected and proactively take appropriate corrective actions.

Privacy Regulations and Generally Accepted Privacy Principles

Concerns about protecting individual privacy have resulted in numerous government regulations.

THE EUROPEAN UNION'S GENERAL DATA PRIVACY REGULATION AND U.S. LAWS

One of the strictest and most far-reaching privacy regulations is the EU's GDPR. The GDPR imposes huge fines (up to 4% of global revenues) for issues such as not properly obtaining consent to collect and use personal information or not being able to document that the organization has taken a proactive approach to protecting privacy (referred to as "privacy by design"). The GDPR affects an organization's security measures, particularly its incident response process, because it requires organizations to notify regulators within 72 hours of discovering a breach. The GDPR also grants people a number of new rights, including access to the data that organizations have about them, correction of errors in that stored data, deletion of personal information stored about them (referred to as the "right to be forgotten"), and revocation of consent to sell or share their information with other organizations. Although it is an EU regulation, the GDPR affects any organization that collects and stores information about European residents, which means, given that most companies do business globally, that it applies to virtually every organization. Likewise, the California Consumer Privacy Act (CCPA) of 2018, which contains provisions similar to the GDPR and applies to California residents, affects most organizations because almost every company has customers in California. In addition to the CCPA and other state disclosure laws, a number of federal regulations, including the Health Insurance Portability and Accountability Act (HIPAA), the Health Information Technology for Economic and Clinical Health (HITECH) Act, and the Financial Services Modernization Act (commonly referred to as the Gramm–Leach–Bliley Act, representing the names of its three congressional sponsors), impose specific requirements on organizations to protect the privacy of their customers' personal information.

Both the EU's GDPR and the CCPA recognize a right for individuals to request that organizations delete personal information collected about them. However, this is easier said than done. One difficulty is that many organizations do not even know all the data that they possess or where it is stored. Another issue concerns how to erase all the information stored in backups and archives. Furthermore, some technologies, like blockchain, are designed to prevent the alteration or deletion of information from certain kinds of records. Nevertheless, organizations must at least attempt to comply with such requests to the extent practicable.

One major difference between the EU's GDPR and the various U.S. regulations is in the manner by which organizations obtain consent to collect an individual's personal information. The default policy in Europe is **opt-in**, meaning that organizations cannot collect personally identifying information unless individuals explicitly give them permission to do so. The GDPR further requires that consent must be demonstrated by a clear affirmative act (i.e., websites cannot use "pre-ticked boxes") and that people must truly have a "free choice" such that they can continue to interact with the organization or website, albeit in a more restricted manner, even when they withhold their consent. In the United States, the default policy is called **opt-out**, which means that organizations can assume "implicit consent" and therefore can collect personal information about individuals unless a person explicitly objects. However, the Privacy Management Framework recommends that even in the United States, organizations should follow the opt-in approach and obtain explicit positive consent prior to collecting and storing *sensitive* personal information, such as financial or health records, political opinions, religious beliefs, and prior criminal history.

opt-in - Referred to as explicit consent because organizations cannot collect and use customers' personal information unless they explicitly agree to allow such actions.

opt-out - Referred to as implicit consent because companies can assume it is okay to collect and use customers' personal information unless they explicitly object.

PRIVACY MANAGEMENT FRAMEWORK

To help organizations cost-effectively comply with these myriad requirements, the American Institute of Certified Public Accountants (AICPA) and the Chartered Institute of Management

Accountants jointly developed the Privacy Management Framework, which identifies and defines the following nine components for protecting the privacy of customers' personal information:

1. **Management.** Organizations need to define and document procedures and policies for protecting the privacy of personal information they collect from customers as well as information about their customers obtained from third parties such as credit bureaus. They should assign responsibility and accountability for implementing those policies and procedures to a specific person or group of employees. Indeed, the GDPR requires that certain kinds of organizations must create the position of a Data Privacy Officer.
2. **Agreement, notice, and communication.** An organization should execute formal agreements, provide notices, and formally communicate its privacy policies and practices at or before the time it collects personal information. Organizations also need to timely communicate any changes to privacy policies and practices and obtain data subjects' agreement with those changes.
3. **Collection and creation.** An organization should collect only the information needed to fulfill the purposes stated in its privacy policies. It should clearly communicate what data it collects, inform data subjects of the option to withhold their consent to such collection, and explain the consequences of that decision. This principle has implications for the use of cookies on websites. A **cookie** is a text file created by a website and stored on a visitor's hard disk. Cookies store information about what the user has done on the site. Most websites create multiple cookies per visit to make it easier for visitors to navigate to relevant portions of the website. It is important to note that cookies are text files, which means they cannot "do" anything besides store information. They do, however, contain personal information that may increase the risk of identity theft and other privacy threats. Browsers can be configured to not accept cookies, and organizations should employ procedures to accede to such requests and not surreptitiously use cookies.

Organizations also need to develop policies regarding what personal information they collect about their employees. This is particularly important as more work is done remotely. Employers have a legitimate need to monitor the performance of remote employees to ensure that they are indeed working. However, organizations also need to ensure that monitoring tools do not invade employee privacy. They also should consider the effects of different levels of monitoring on both employee morale and overall productivity. Think about it: Do you perform at your best when you think the boss is standing there looking over your shoulder? Indeed, there is some research evidence that excessive monitoring actually increases *misbehavior* ("if they don't trust me . . .") and *decreases* productivity ("I'll show them . . .").

4. **Use, retention, and disposal.** Organizations should use customers' personal information only in the manner described in their stated privacy policies and retain that information only as long as it is needed to fulfill a legitimate business purpose. When the information is no longer useful, it should be disposed of in a secure manner. This means that organizations need to create policies to ensure that *all* devices (desktops, laptops, tablets, copiers, etc.) that have been used to store personal information are properly "sanitized" by securely wiping all information stored in the device before disposing of it. Organizations also need to assign someone responsibility for ensuring compliance with those policies. The need to focus on the final stage of the information life cycle (deletion) has become more important now that both the GDPR and the CCPA establish a right for customers to request that an organization securely delete information about them. Note that deletion of data no longer used not only complies with regulations, but also provides an economic benefit by reducing the potential costs from a data breach because the organization will need to notify and provide compensation, such as free credit monitoring, to fewer people affected by the incident.
5. **Access.** An organization should provide individuals with the ability to access, review, and correct the personal information stored about them.
6. **Disclosure to third parties.** Organizations should obtain explicit consent before disclosing their customers' personal information to third parties. This principle has implications for using cloud computing because storing customers' personal information in the cloud may make it accessible to the cloud provider's employees; hence, any personal information stored in a public cloud should be encrypted at all times.

cookie - A text file created by a website and stored on a visitor's hard drive. Cookies store information about who the user is and what the user has done on the site.

7. Security for privacy. An organization must take reasonable steps to protect its customers' personal information from loss or unauthorized disclosure. Indeed, it is not possible to protect privacy without adequate information security. Therefore, organizations must use the various preventive, detective, and corrective controls discussed in **Chapter 11** to restrict access to their customers' personal information. Moreover, they must ensure that such controls apply to *both* digital information *and* paper copies.

However, achieving an acceptable level of information security is not sufficient to protect privacy because security only protects against unauthorized access to the data but does not control what authorized users do with that data. It is also necessary to train employees to avoid practices that can result in the unintentional or inadvertent breach of privacy. E-mail presents a threat vector to consider. For example, several years ago drug manufacturer Eli Lilly sent an e-mail about its antidepressant drug Prozac to 669 patients. However, because it used the cc: function to send the message to all patients, the e-mails revealed the identities of other patients. Another often-overlooked area concerns the release of electronic documents. Just as special procedures are used to black out (redact) personal information on paper documents, organizations should train employees to use procedures to remove such information on electronic documents in a manner that prevents the recipient of the document from recovering the redacted information.

It is not possible to ensure personal information is adequately protected unless you are aware that you possess the information and know where it is stored. Yet, organizations likely possess a great deal of personal information that was collected, stored, and then forgotten. Examples include resumes received from people not hired and school applications from people who were not accepted or who chose not to attend. Management needs to regularly ask how much of this "dark data" exists, where it is stored, whether it should be destroyed, and, if it needs to be retained, how it is being protected.

8. Data integrity and quality. Organizations should ensure that any personal information that is collected and stored is accurate, reliable, up to date, and relevant. Providing customers with a way to review the personal information stored by the organization (as discussed in principle 5) can be a cost-effective way to achieve this objective.

9. Monitoring and enforcement. Organizations must periodically verify that their employees are complying with stated privacy policies. In addition, organizations should establish procedures for responding to customer complaints, including the use of a third-party dispute resolution process.

In summary, the Privacy Management Framework shows that protecting the privacy of customers' personal information requires first implementing a combination of policies, procedures, and technology, then training everyone in the organization to act in accordance with those plans, and subsequently monitoring compliance. Only senior management possesses the authority and the resources to accomplish this, which reinforces that all aspects of systems reliability are, at bottom, a managerial issue and not just an IT issue. Because accountants and auditors serve as trusted advisors to senior management, they too need to be knowledgeable about these issues.

IDENTITY THEFT One privacy-related issue of growing concern is identity theft. **Identity theft** is the unauthorized use of someone's personal information for the perpetrator's benefit. Often, identity theft is a financial crime, in which the perpetrator obtains loans or opens new credit cards in the victim's name and sometimes loots the victim's bank accounts. However, a growing proportion of identity theft cases involve fraudulently obtaining medical care and services. Medical identity theft can have life-threatening consequences because of errors it may create in the victim's medical records, such as changing information about drug allergies or prescriptions. It may even cause victims to lose their insurance coverage if the thief has used up their annual or lifetime cap for coverage of a specific illness. Tax identity theft is another growing problem. Perpetrators typically use the victim's Social Security number to file a fraudulent claim for a refund early in the tax-filing season. Victims only learn of the crime after filing their tax return and then receiving a letter from the IRS informing them that more than one return was filed using their Social Security number. It can take months for victims to resolve the problem and obtain any legitimate refund they are due.

identity theft - Assuming someone's identity, usually for economic gain, by illegally obtaining confidential information such as a Social Security number or a bank account or credit card number.

FOCUS 12-1 Protecting Yourself from Identity Theft

Victims of identity theft often spend much time and money to recover from it. Fortunately, there are a number of simple steps you can take to minimize your risk of becoming a victim of identity theft.

- Contact all major credit bureaus and put a credit freeze in place.
- Shred all documents that contain personal information, especially unsolicited credit card offers, before discarding them. Crosscut shredders are much more effective than strip-cut shredders.
- Securely store documents that contain sensitive personal and financial information (e.g., tax returns and financial statements). Paper documents should be kept in a locked file cabinet and digital files should be encrypted.
- Never send personal information (Social Security number, passport number, etc.) in unencrypted e-mail.
- Beware of e-mail, telephone, and print requests to “verify” personal information that the requesting party should already possess. For example, credit card companies will never need to ask you for the three- or four-digit security code on your card. Similarly, the IRS will never e-mail you asking you to send personally identifying information in response to an audit or in order to obtain your refund.
- Do not carry your Social Security card with you.
- Resist requests to provide your Social Security number to businesses that ask for it, as it is seldom needed for most transactions.
- Print only your initials and last name, rather than your full name, on checks. This prevents a thief from knowing how you sign your name.
- Limit the amount of other information (address and phone number) preprinted on checks, and consider totally eliminating such information.
- Do not place outgoing mail containing checks or personal information in your mailbox for pickup.
- Do not carry more than a few blank checks with you.
- Use special software to thoroughly clean any digital media prior to disposal, or physically destroy the media. It is especially important to thoroughly erase or destroy hard drives (for computers, printers, and copy machines) prior to donating or disposing of obsolete equipment because they likely contain information about financial transactions.
- Monitor your credit reports regularly.
- File a police report as soon as you discover that your purse or wallet was lost or stolen.
- Make photocopies of driver’s licenses, passports, and credit cards. Store this information, along with the telephone numbers of all your credit cards, in a safe location to facilitate notifying appropriate authorities in the case that those documents are lost or stolen.
- Immediately cancel any stolen or lost credit cards.

Focus 12-1 discusses the steps that individuals should take to minimize the risk of becoming a victim of any of these forms of identity theft. Organizations, however, also have a role to play in preventing identity theft. Customers, employees, suppliers, and business partners entrust organizations with their personal information. Organizations economically benefit from having access to that information. Therefore, in addition to regulatory requirements, organizations have an ethical and moral obligation to implement controls to protect the personal information that they collect.

Encryption

Encryption is a preventive control that can be used to protect both confidentiality and privacy. Encryption protects data while it is in transit over the Internet and provides one last barrier that must be overcome by an intruder who has obtained unauthorized access to stored information. As we will see later, encryption also strengthens authentication procedures and plays an essential role in ensuring and verifying the validity of e-business transactions. Therefore, it is important for accountants, auditors, and systems professionals to understand encryption.

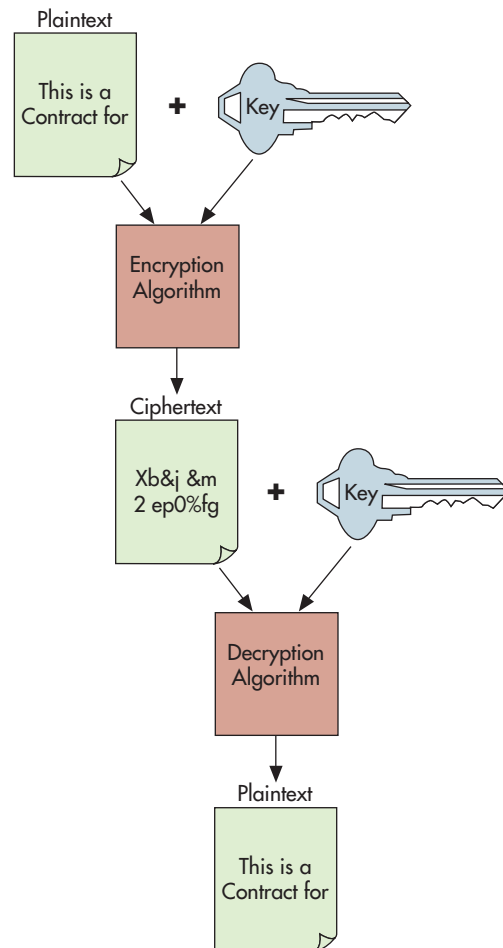
As shown in Figure 12-2, **encryption** is the process of transforming normal content, called **plaintext**, into unreadable gibberish, called **ciphertext**. **Decryption** reverses this process, transforming ciphertext back into plaintext. Figure 12-2 shows that both encryption and decryption involve use of a key and an algorithm. Computers represent both plaintext and

encryption - The process of transforming normal text, called *plaintext*, into unreadable gibberish, called *ciphertext*. Encryption is particularly important when confidential data is being transmitted from remote terminals because data transmission lines can be electronically monitored without the user’s knowledge.

plaintext - Normal text that has not been encrypted.

ciphertext - Plaintext transformed into unreadable gibberish using encryption.

decryption - Transforming ciphertext back into plaintext.

**FIGURE 12-2**

Steps in the Encryption and Decryption Process

ciphertext as a series of binary digits (0s and 1s). Encryption and decryption keys are also strings of binary digits; for example, a 256-bit key consists of a string of 256 0s and 1s. The algorithm is a formula for using the key to transform the plaintext into ciphertext (encryption) or the ciphertext back into plaintext (decryption). Most documents are longer than the key, so the encryption process begins by dividing the plaintext into blocks, with each block equal in length to the key. Then the algorithm is applied to the key and each block of plaintext. For example, if a 512-bit key is used, the computer first divides the document or file into 512-bit-long blocks and then combines each block with the key in the manner specified by the algorithm. The result is a ciphertext version of the document or file, equal in size to the original. To reproduce the original document, the computer first divides the ciphertext into 512-bit blocks and then applies the decryption key to each block.

FACTORS THAT INFLUENCE ENCRYPTION STRENGTH

Three important factors determine the strength of any encryption system: (1) key length, (2) encryption algorithm, and (3) policies for managing the cryptographic keys.

KEY LENGTH Longer keys provide stronger encryption by reducing the number of repeating blocks in the ciphertext. This makes it harder to spot patterns in the ciphertext that reflect patterns in the original plaintext. For example, a 24-bit key encrypts plaintext in blocks of 24 bits. It takes 8 bits to represent each letter in the English language. Thus, a 24-bit key encrypts English plaintext in chunks of three letters. This makes it easy to use information about relative word frequencies, such as the fact that *the* is one of the most common three-letter words in English, to “guess” that the most commonly recurring pattern of 24 bits in the ciphertext probably represents the word *the* and proceed from that point to guess other common three- and

four-letter words, thereby “breaking” the encryption. That’s why most encryption keys are at least 256 bits long (corresponding to 32 English letters) and often 1,024 bits or longer.

ENCRYPTION ALGORITHM The nature of the algorithm used to combine the key and the plaintext is important. A strong algorithm is difficult, if not impossible, to break by using brute-force guessing techniques. This does *not* mean that the algorithm itself must be secret. Indeed, the procedures used by the most accepted and widely used encryption algorithms are publicly available. Their strength is due not to the secrecy of their procedures but to the fact that they have been rigorously tested and demonstrated to resist brute-force guessing attacks. Therefore, organizations should not attempt to create their own “secret” encryption algorithm but instead should purchase products that use widely accepted standard algorithms whose strength has been proven.

Existing standard encryption algorithms are resistant to attacks by even large networks of current computers and are thus more than adequate to support e-business. However, as **Focus 12-2** discusses, *all* existing encryption algorithms are vulnerable to quantum computers. Fortunately, this development was foreseen years ago, and research was begun to find new encryption algorithms that are resistant to quantum computing. In July 2022, the National Institute of Standards and Technology (NIST) selected four algorithms that have been proven to be robust against attacks using quantum computers. All four algorithms are “open” (i.e., the algorithm is not secret), but they are not “open source” so organizations will have to purchase commercial software that implements those algorithms.

Organizations need to begin planning now to transition to these new post-quantum encryption solutions because doing so will require a significant investment of time and money. Indeed, preparation itself involves two time-consuming activities. The first is to create an inventory of all encrypted data stored on the organization’s and its employees’ devices, as well as what is stored in the cloud. Then it is necessary to classify all of that information in terms of value so that the organization can prioritize what needs to be migrated first.

POLICIES FOR MANAGING CRYPTOGRAPHIC KEYS The management of cryptographic keys is often the most vulnerable aspect of encryption systems. No matter how long the keys are or how strong an encryption algorithm is, if the keys have been stolen, the encryption can

FOCUS 12-2 Quantum Computing and Encryption

Quantum computers can break encryption algorithms because they are massively more powerful than classical computers. Classical computers are based on electricity and, therefore, store information in one of two states (on or off) that are represented in the form of binary digits (bits) as either a 0 or a 1. In contrast, quantum computers are based on two important principles of quantum physics: superposition and entanglement. Superposition means that a quantum bit (qubit) can be in both states (on/off, 0/1) at the same time. Entanglement means that each qubit is interconnected with the others, so that changing one affects the other. The result is a massive increase in computing power and speed that can use brute-force guessing attacks to break existing standard encryption algorithms.

Fortunately, quantum computers are currently limited in size and are unlikely to become practical on a large scale soon. The first quantum computer was built at

Yale in 2009, and was capable of processing only 2 qubits; in 2021, IBM built a 127-qubit quantum computer. A major impediment to the growth of quantum computing is that quantum computers can only operate in environments with extremely low temperatures. Therefore, most experts predict that quantum computing will not become practical until the 2030s.

Nevertheless, organizations must take steps now to improve the security of systems that house extremely valuable information because of the threat of attackers stealing the encrypted data today with the hope of decrypting it when quantum computing becomes practical. This threat is especially dangerous for companies such as pharmaceutical firms that routinely engage in R&D efforts that may take a decade or more to reach fruition because if an attacker can steal that information today and decrypt it before a new drug has been brought to market, most of the company’s “head start” on developing that new drug vanishes.

TABLE 12-1 Comparison of Symmetric and Asymmetric Encryption Systems

	Symmetric encryption	Asymmetric encryption
Number of keys	One key. Same secret key used both to encrypt and decrypt.	Two keys. One key is made public, the other kept private. Either key can encrypt, but only the other matching key can decrypt.
Advantages	● Speed—much faster.	● Everyone can use your public key to communicate with you. ● No need to store keys for each person with whom you wish to communicate. ● Can be used to create legally binding digital signatures.
Disadvantage	● Requires separate key for everyone who wishes to communicate. ● Must find secure way to share the secret key with the other party	● Speed—much slower. ● Requires public key infrastructure (PKI, to be discussed later) to validate ownership of public keys.
Risk issues	● Protecting shared secret key from loss or theft.	● Protecting private key from loss or theft.
Primary use	● Encryption of large amounts of information.	● Creation of digital signatures. ● Secure exchange of symmetric keys via e-mail.

be easily broken. Therefore, cryptographic keys must be stored securely and protected with strong access controls. Best practices include (1) not storing cryptographic keys in a browser or any other file that other users of that system can readily access and (2) using a strong (and long) passphrase to protect the keys.

Organizations also need sound policies and procedures for issuing and revoking keys. Keys should be issued only to employees who handle sensitive data and need the ability to encrypt it. It is also important to promptly revoke (cancel) keys when an employee leaves or when there is reason to believe the key has been compromised and to notify everyone who has relied upon those keys that they are no longer valid.

TYPES OF ENCRYPTION SYSTEMS

Table 12-1 compares the two basic types of encryption systems. **Symmetric encryption systems** use the same key both to encrypt and to decrypt. AES is an example of a symmetric encryption system. It is commonly included in most operating systems. **Asymmetric encryption systems** use two keys that are created as a matched pair. One key, called the **public key**, is widely distributed and made available to everyone; the other, called the **private key**, is kept secret and known only to the owner of that pair of keys. RSA* and elliptic curve cryptography are examples of asymmetric encryption systems.

Either the public or the private asymmetric key can be used to encrypt, but only the other matching key in that pair can decrypt. Thus, anyone can use the public key to encrypt a file and securely send it to the owner of that key because only the owner possesses the corresponding private key and therefore is the only person who can decrypt that file. Conversely, encrypting something with your private key makes it possible for anyone to verify that you sent that file: If the recipient can successfully decrypt the file using your public key, it proves that the file must have been encrypted by you because you are (or should be) the only person with access to your private key.

For both types of encryption systems, loss or theft of the encryption keys are major threats. Should the keys be lost, the encrypted information cannot be recovered. One solution

symmetric encryption systems - Encryption systems that use the same key both to encrypt and to decrypt.

asymmetric encryption systems - Encryption systems that use two keys (one public, the other private); either key can encrypt, but only the other matching key can decrypt.

public key - One of the keys used in asymmetric encryption systems. It is widely distributed and available to everyone.

private key - One of the keys used in asymmetric encryption systems. It is kept secret and known only to the owner of that pair of public and private keys.

* RSA encryption algorithm is named after its inventors: Ron Rivest, Adi Shamir, and Leonard Adleman. The initials of their last names form the acronym "RSA."

key escrow - The process of storing a copy of an encryption key in a secure location.

to this is to use encryption software that creates a built-in master key that can be used to decrypt anything encrypted by that software. An alternative is a process called **key escrow**, which involves making copies of all encryption keys used by employees and storing those copies securely. Theft of the encryption keys eliminates the value of encryption. In symmetric systems, if the shared secret key is stolen, the attacker can access any information encrypted with it. In asymmetric systems, the public key is intended to be widely distributed, but the private key must be stored securely. If your private key is compromised, the attacker will not only be able to decrypt all information sent to you by other people who encrypted that information with your public key, but also be able to use your private key to impersonate you and even create legally binding digital signatures (which we will explain later) in your name.

Symmetric encryption is much faster than asymmetric encryption, but it has two major problems. First, both parties (sender and receiver) need to know the shared secret key. This means that the two parties need to have some method for securely exchanging the key that will be used to both encrypt and decrypt. E-mail is not a solution because anyone who can intercept the e-mail would know the secret key. Thus, some other method of exchanging keys is needed. Although this could be done by telephone, postal mail, or private delivery services, such techniques quickly become cost-prohibitive, particularly for global communications. The second problem is that a separate secret key needs to be created for use by each party with whom the use of encryption is desired. For example, if Company A wants to encrypt information it shares with companies B and C but prevent B and C from having access to the other's information, it needs to create two encryption keys, one for use with Company B and the other for use with Company C. Otherwise, if Company A shared only one common secret key with both B and C, either company could decrypt any information to which it obtained access, even if intended for the other company. Thus, secure management of keys quickly becomes more complex as the number of participants in a symmetric encryption system increases.

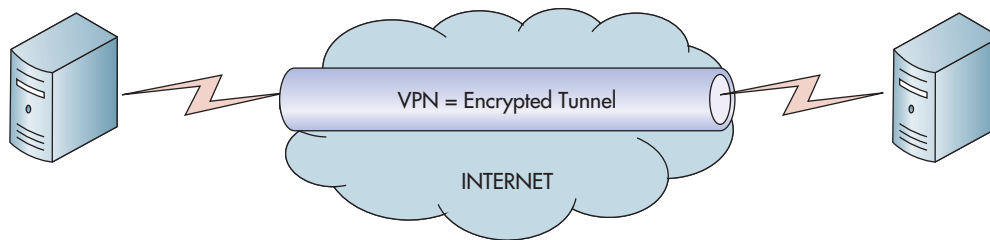
Asymmetric encryption systems solve both of these problems. It does not matter who knows the public key because any text encrypted with the public key can only be decrypted by using the corresponding private key. Therefore, the public key can be distributed by e-mail or even be posted on a website so that anyone who wants to can send encrypted information to the owner of that public key. Also, any number of parties can use the same public key to send encrypted messages because only the owner of the corresponding private key can decrypt the messages. Returning to our earlier example, both companies B and C can use Company A's public key to communicate securely with A. Company B need not fear that Company C could intercept that communication because the information can only be decrypted by using Company A's private key, which Company C does not have. Asymmetric encryption systems also greatly simplify the process of managing cryptographic keys. Company A does not need to create and manage separate keys for each company from which it wants to receive information securely over the Internet; instead, it needs to create just one pair of public and private keys. Company A also does not need to store the public keys of other companies to which it wishes to send information securely because it can always obtain the other company's public key from that company's website or via e-mail.

The main drawback to asymmetric encryption systems is speed. Asymmetric encryption is much (thousands of times) slower than symmetric encryption, making it impractical for exchanging large amounts of data over the Internet. Consequently, e-business uses both types of encryption systems. Symmetric encryption is used to encode most of the data being exchanged, and asymmetric encryption is used to safely send via e-mail the symmetric key to the recipient for use in decrypting the ciphertext. The shared secret key is secure even though it is sent via e-mail because if the sender uses the recipient's public key to encrypt it, only the intended recipient, who is the only person possessing the corresponding private key, can decrypt that shared secret symmetric key. As will be discussed later, asymmetric encryption is also used in combination with a process called *hashing* to create legally binding digital signatures.

virtual private network (VPN) - Using encryption and authentication to securely transfer information over the Internet, thereby creating a "virtual" private network.

VIRTUAL PRIVATE NETWORKS (VPNs)

To protect confidentiality and privacy, information must be encrypted not only within a system, but also when it is in transit over the Internet. As Figure 12-3 shows, encrypting information while it traverses the Internet creates a **virtual private network (VPN)**, so named because it

**FIGURE 12-3**Virtual Private Networks
[VPNs]

provides the functionality of a privately owned secure network without the associated costs of leased telephone lines, satellites, and other communication equipment. Using VPN software to encrypt information while it is in transit over the Internet in effect creates private communication channels, often referred to as *tunnels*, which are accessible only to those parties possessing the appropriate encryption and decryption keys. VPNs also include controls to authenticate the parties exchanging information and to create an audit trail of the exchange. Thus, VPNs ensure that sensitive information is exchanged securely and in a manner that can provide proof of its authenticity.

There are two basic types of VPNs. One type uses a browser, encrypting the traffic with SSL or TLS (the same protocols that produce the familiar “lock” symbol whenever you engage in online shopping or banking); the other type uses IPSec, a version of the IP protocol that incorporates encryption as part of the process of creating IP packets. Both types of VPNs provide a secure means of exchanging sensitive information over the Internet but create problems for other components of information security. For example, recall from **Chapter 11** that firewalls function by inspecting the contents of packets. Firewalls, however, cannot examine packets that are encrypted. There are three commonly used approaches to dealing with this problem. One is to configure the firewall to send encrypted packets to a computer in the demilitarized zone (DMZ) that decrypts them; that computer then sends the decrypted packets back through the firewall for filtering before being allowed into the internal network. Although this approach allows the firewall to screen all incoming packets, it means that sensitive information is unencrypted both in the DMZ and within the internal network. A second approach is to configure the main firewall to allow encrypted packets to enter the internal network and decrypt them only at their final destination. Although this approach protects the confidentiality of sensitive information until it reaches the appropriate destination, it creates potential holes in access controls because not all incoming packets are filtered by the firewall. The third approach is to have the firewall also function as the VPN termination point, decrypting all incoming traffic and then inspecting the content. This approach is costly, creates a single point of failure (if the firewall goes down, so too does the VPN), and means that sensitive information is not encrypted while traveling on the internal corporate network. Thus, organizations must choose which systems reliability objective is more important: confidentiality (privacy) or security. Unfortunately, this type of dilemma is not limited to firewalls; antivirus programs, intrusion prevention systems, and intrusion detection systems also have difficulty in dealing with encrypted packets. This necessity of making trade-offs among different components of systems reliability is another reason that information security and controls is a managerial concern, and not just an IT issue.

Digital Signatures

An important issue for business transactions has always been **nonrepudiation**, or how to create legally binding agreements that cannot be unilaterally repudiated by either party. Traditionally, this has been accomplished by physically signing contracts and other documents. In the event of a dispute, experts can examine the signature to ascertain its genuineness. Today, however, many business transactions occur digitally using the Internet. How can businesses obtain the same level of assurance about the enforceability of a digital transaction that a signed document provides for a paper-based transaction? The answer is to use both hashing and asymmetric encryption to create a legally binding digital signature.

nonrepudiation - Creating legally binding agreements that cannot be unilaterally repudiated by either party.

TABLE 12-2 Comparison of Hashing and Encryption

Hashing	Encryption
1. Any size input yields the same fixed-size output. For example, SHA-256 hashing algorithm produces a 256-bit hash for each of the following: ● a one-sentence document ● a one-page document ● a 10-page document 2. One-way function (cannot reverse, or “unhash” to recover original document).	1. Output size approximately the same as input size. For example: ● a one-sentence document becomes a one-sentence encrypted document ● a one-page document becomes a one-page encrypted document ● a 10-page document becomes a 10-page encrypted document 2. Reversible (can decrypt ciphertext back to plaintext)

HASHING

hashing - Transforming plaintext of any length into a short code called a hash.

hash - Plaintext transformed into short code.

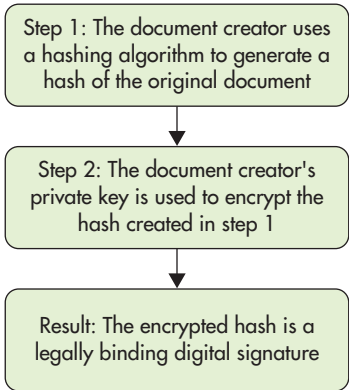
Hashing is a process that takes plaintext of any length and creates a short code called a *message digest*, popularly referred to as a **hash**. For example, the SHA-256 algorithm creates a 256-bit hash, regardless of the size of the original plaintext. Table 12-2 shows that hashing differs from encryption in two important aspects. First, encryption always produces ciphertext similar in size to the original plaintext, but hashing always produces a hash that is of a fixed short length, regardless of the size of the original plaintext. The second difference is that encrypted text can be decrypted, thereby recovering the original plaintext, but it is not possible to transform a hash back into the original plaintext. Thus, sending someone a hash is *not* a way to protect confidentiality or privacy because the recipient can never recover any information from the hash. There is, however, an important property of hashing algorithms that makes it useful to send a hash of a document to another party, along with that original document. Hashing algorithms use every bit in the original plaintext to calculate the hash value. Changing *any* character in the document being hashed, such as replacing a 1 with a 7, adding or removing a single space, or even switching from uppercase to lowercase, produces a different hash value. This property of hashing algorithms provides a means to test the integrity of a document, to verify whether two copies of a document, each stored on a different device, are identical. If each copy is run through the same hashing algorithm and the resulting hashes are the same, then the two copies are identical; if the two hashes are different, then one of the copies has been altered. This ability to verify integrity plays an important role in creating legally binding digital signatures and is an essential component underlying blockchains.

CREATING A DIGITAL SIGNATURE

digital signature - A hash encrypted with the hash creator’s private key.

As Figure 12-4 shows, creating a **digital signature** is a two-step process. The document creator first generates a hash of the document (or file) and then encrypts that hash using their private key. The resulting encrypted hash is a digital signature that provides assurance about two important issues: (1) that a copy of a document or file has not been altered, and (2) who created the original version of a digital document or file. Thus, digital signatures provide

FIGURE 12-4
Creating a Digital Signature



assurance that someone cannot enter into a digital transaction and then subsequently deny they had done so and refuse to fulfill their side of the contract.

How do digital signatures provide this assurance? First, remember that an important property of a hash is that it reflects every bit in a document. Therefore, if two hashes are identical, it means two documents or files are identical. Consequently, just as a photocopy can be compared to an original to verify that it has not been altered, comparing a hash of a document on one computer to a hash of a document on another computer provides a way to determine whether two documents are identical. Second, remember that in asymmetric encryption systems, something encrypted with a private key can only be decrypted with the corresponding public key. Therefore, if something can be decrypted with an entity's public key, it must have been encrypted with that entity's corresponding private key, which proves that the information had to have been encrypted by the owner of that pair of public and private keys.

Figure 12-5 shows how both of these facts work together to provide nonrepudiation. A customer creates a purchase order and a digital signature for that order. The customer sends both the purchase order and the digital signature to the supplier, along with information about which hashing algorithm was used to create the digital signature. The supplier uses the stated hashing algorithm to generate a hash from its copy of the purchase order. The supplier also uses the customer's public key to decrypt the customer's digital signature. The result of decrypting the digital signature is a hash. If the supplier successfully uses the customer's public key to decrypt the customer's digital signature, it proves that the customer did indeed create and send that digital signature. It also proves that the customer must have possessed some file or document that was first hashed and then encrypted using the customer's private key to create that digital signature. If the hash obtained by decrypting the customer's digital signature matches

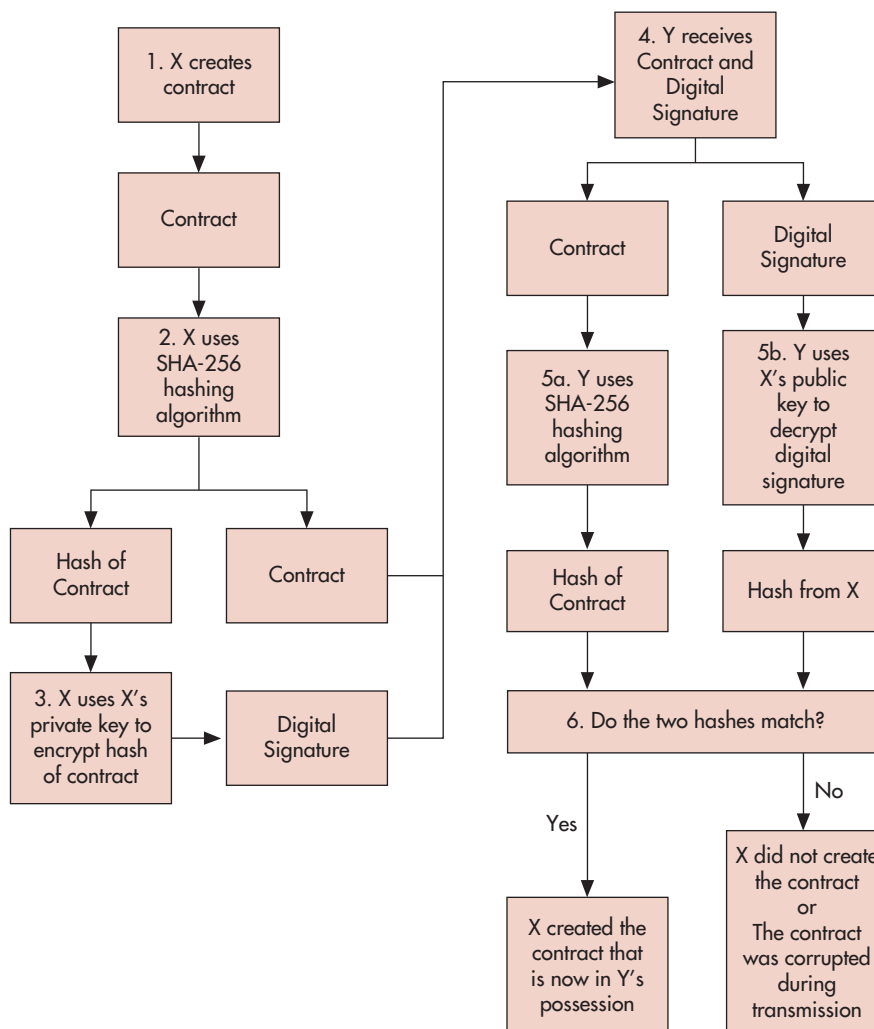


FIGURE 12-5
Example of Digital
Signature Usage

the hash created by running the supplier's copy of the purchase order through the same hashing algorithm, it proves that the document used by the customer to create its digital signature was the purchase order now possessed by the supplier. Thus, the customer cannot unilaterally repudiate (deny making) the order in the event of a dispute because the supplier can follow the steps just described to prove that the customer did indeed create and send that purchase order.

One question still remains, however. Successfully using a public key to decrypt a document or file proves that the party possessing the corresponding private key created it. But how can the recipient be sure of the other party's identity? Returning to our prior example, how can a supplier know that the public key purportedly belonging to a customer really belongs to a legitimate customer and not to a hacker who created that pair of public and private keys? For that matter, how does the supplier obtain the customer's public key? The answers to these questions involve the use of digital certificates and a public key infrastructure.

DIGITAL CERTIFICATES AND PUBLIC KEY INFRASTRUCTURE

Usually, you obtain another party's public key by going to their website, where your browser automatically extracts the public key from the site's digital certificate. (You can manually examine the contents of a website's digital certificate by double-clicking on the lock icon that appears in your browser window when you visit a website.) A **digital certificate** is an electronic document that contains an entity's public key and certifies the identity of the owner of that particular public key. Thus, digital certificates function like the digital equivalent of a driver's license or passport. Just as passports and drivers' licenses are issued by a trusted independent party (the government) and employ mechanisms such as holograms and watermarks to prove they are genuine, digital certificates are issued by an organization called a **certificate authority** and contain the certificate authority's digital signature to prove they are genuine. Commercial certificate authorities typically issue digital certificates intended for e-business use. Most certificate authorities charge a fee to issue a pair of public and private keys and collect evidence to verify the claimed identity of the person or organization purchasing those keys and the corresponding digital certificate.

This system for issuing pairs of public and private keys and corresponding digital certificates is called a **public key infrastructure (PKI)**. The entire PKI system hinges on trusting the certificate authorities that issue the keys and certificates. One important factor concerns the procedures the certificate authority uses to verify the identity of an applicant for a digital certificate. Several classes of digital certificates exist. The cheapest, and least trustworthy, may involve nothing more than verifying the applicant's e-mail address. The most expensive certificates may require verification of the applicant's identity through use of credit reports and tax returns. Digital certificates are valid for only a specified period of time. Thus, a second important criterion for assessing the reliability of a certificate authority is the procedures it uses to update certificates and revoke expired digital certificates.

Browsers are designed to automatically check the validity of a website's digital certificate. The issuing certificate authority signs digital certificates, and browsers come preloaded with the public keys of widely recognized certificate authorities. The browser uses that stored public key to decrypt the certificate authority's digital signature, which yields a hash of the digital certificate. The browser then creates its own hash of the digital certificate; if the two hashes match, the certificate is valid. If not, the browser displays a warning that site's certificate is invalid and asks you whether you want to proceed. Browsers also check the expiration date of a digital certificate and warn you if it has expired. Note that browsers play a critical role in PKI. If a hacker can compromise your browser and store their public key, your browser can be tricked into accepting a fake digital certificate created and signed by the criminal. The best way to prevent this threat is to always be sure your browser is fully patched and up to date.

Blockchain

Hashing also plays an integral role in blockchains. Blockchain technology was originally developed to support the cryptocurrency Bitcoin to prevent "double-spending" the same coin, but it has since been adopted for use in a variety of industries to create reliable audit trails for any business process. A **blockchain** is a distributed ledger of hashed documents with copies

digital certificate - An electronic document that certifies the identity of the owner of a particular public key and contains that party's public key.

certificate authority - An organization that issues public and private keys and records the public key in a digital certificate.

public key infrastructure (PKI) - The system for issuing pairs of public and private keys and corresponding digital certificates.

blockchain - Individual digital records, called *blocks*, linked together using cryptography in a single list, called a *blockchain*. The blockchain isn't stored in a single location. Instead, it is a distributed ledger of hashed documents that functions as a decentralized database. Each computer in the distributed peer-to-peer network maintains a copy of the ledger to prevent a single point of failure.

stored on multiple computers. An important characteristic of a blockchain is that it cannot be unilaterally altered by any one entity. (However, a majority of participants, or a centralized authority running a non-public blockchain, can agree to alter the blockchain. For example, after a theft of a large amount of the cryptocurrency Ethereum, participants agreed to alter the blockchain to prevent the stolen “coins” from being used.)

Figure 12-6 shows the role of hashing in the three-step process that creates a blockchain. In this example, a blockchain is created to serve as an audit trail for a business process. Step 1 begins by collecting a batch of documents and calculating hash values for each document. Pairs of those hashes are then concatenated together, and that result is in turn hashed. This is repeated until just one root hash for the entire block has been created. Step 2 then validates the new block by a process called *mining*, which uses three inputs (a random number, called a **nonce**; the root hash just calculated in step 1; and the root hash of the most recently validated block in the chain) to generate a header hash value that begins with a prescribed number of leading zeroes. The number of leading zeroes is arbitrary and agreed on by all participants in a specific blockchain network. For example, a blockchain network consisting of all the members in a manufacturer’s supply chain might be designed to require that a block-validating header hash must begin with six leading zeroes. In that case, mining would involve repeatedly generating a nonce and then hashing the combination of (1) that nonce, (2) the root hash of the newest block, and (3) the root hash of the last validated block in the chain until a nonce is found that generates a header hash with six leading zeroes. Once such a header hash value is generated, it becomes the block-validating hash value that will be stored in the header of this new block of transactions. Finally, the newly validated block is appended to the end of the existing chain (step 3a in Figure 12-6), and then the updated chain is copied to all other participants in the blockchain network (step 3b in Figure 12-6). The process then repeats for each new block of documents.

nonce - A random number; used in the mining process to validate a new block in a blockchain.

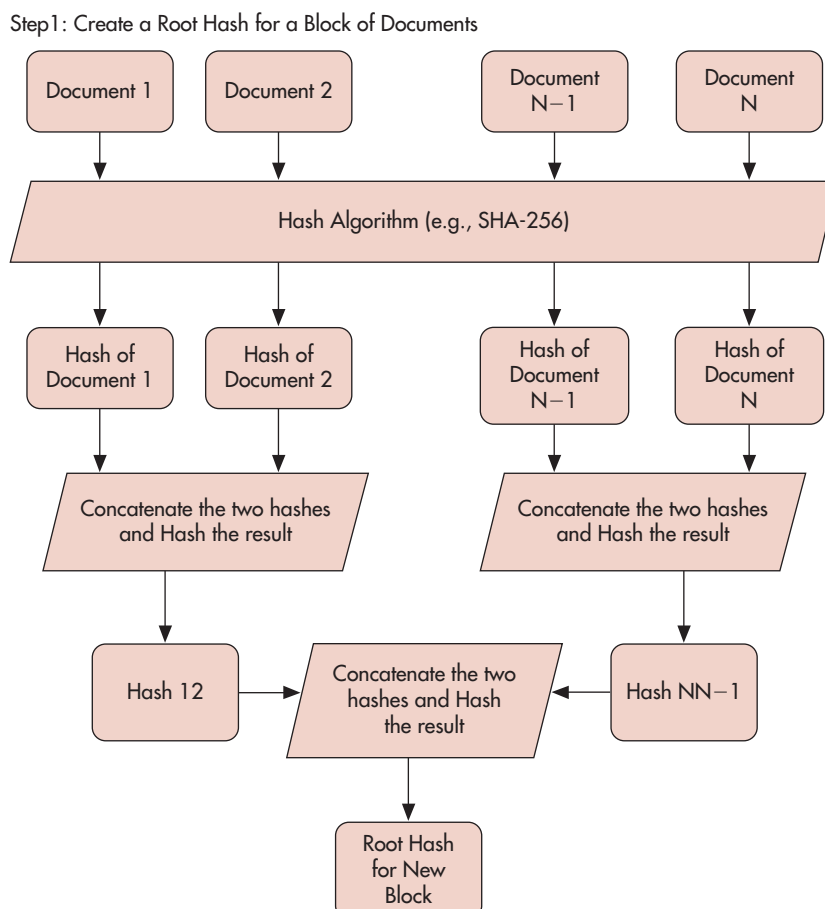
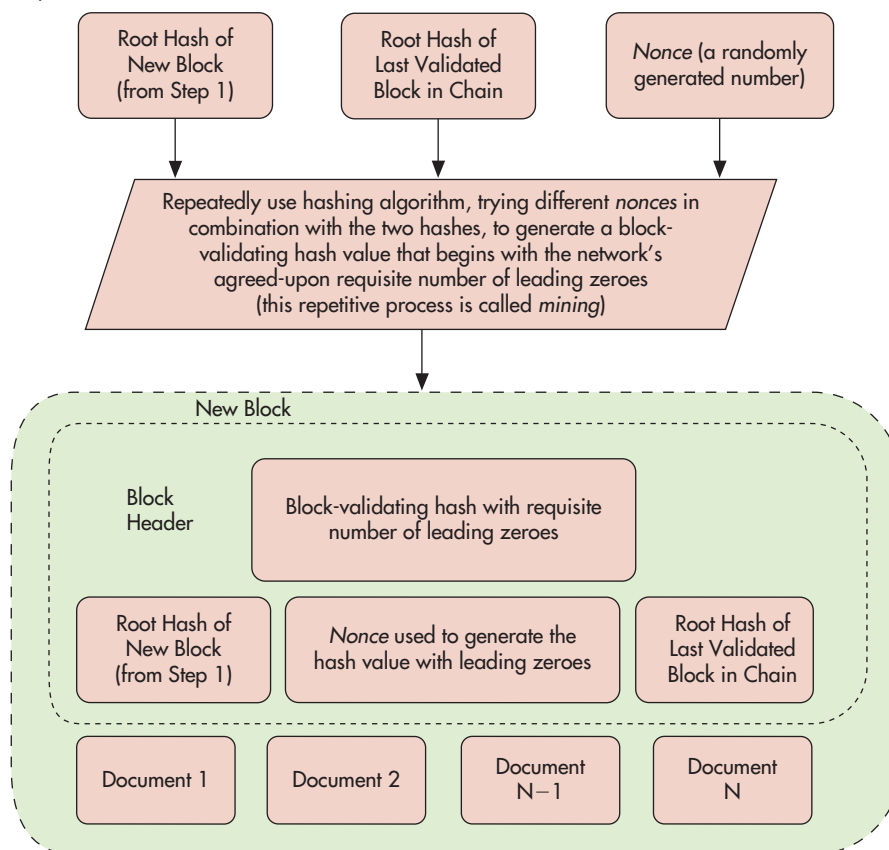
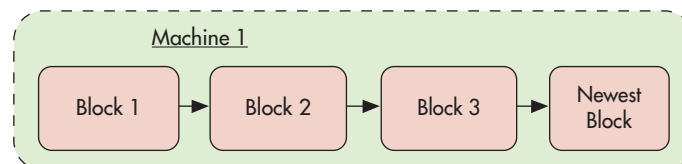


FIGURE 12-6
How Hashing Updates
a Blockchain

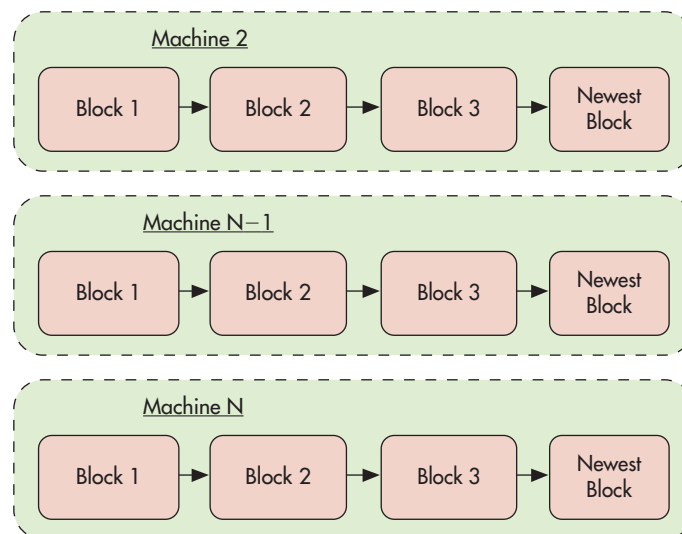
Step 2: Validate the new block and store the validation number in block header



Step 3a: Append the New Block to Existing Chain



Step 3b: Copy the updated blockchain to computers of all other participants in that blockchain network.



Let's examine why this three-step blockchain procedure creates a reliable audit trail. Recall that hashing produces a unique value for the data being hashed. Therefore, any change in the underlying data results in a different hash value. Consequently, if someone edits one of the underlying documents, such as changing the terms in a particular sales invoice, the altered document would have a different hash value than the original. Now refer back to step 1 in Figure 12-6. If the hash of one of the documents in a block changes, so too would all subsequent hashes generated from pairs of documents. Ultimately, the root hash for the entire batch would be different than what it was originally. Consequently, step 2 in the process would not work because the combination of the new root hash, the root hash of the previously validated block, and the nonce would no longer generate a header hash with the required number of leading zeroes. Now, it is theoretically possible for the person who altered the original document to simply redo the mining process in step 2 to find a new nonce that generates a header hash with the requisite number of leading zeroes for the altered batch of transactions. The person could then repeat that process for each subsequent block in the chain and eventually create a new blockchain. However, all that effort would only change the copy of the blockchain stored on that one computer. But the altered blockchain would not match the copies distributed on the computers of all the other participants in the blockchain network. Thus, the distributed nature of the blockchain provides a means to identify any attempts to unilaterally alter any of the original documents, which is why the blockchain process creates a reliable audit trail.

Nevertheless, a blockchain will only produce a reliable audit trail if it has been properly implemented. Just as errors in implementing encryption can introduce vulnerabilities that negate the value of encryption, errors in implementing blockchain can result in unreliable records. Thus, auditors will need to be able to examine a blockchain to verify that it is working correctly.

Summary and Case Conclusion

Jason Sun reviewed what he learned about Northwest Industries' information systems controls to protect confidentiality and privacy. Confidential information about business plans and personal information collected from customers was encrypted both in storage and whenever it was transmitted over the Internet. Employee laptops were configured with VPN software so they could securely access the company's information systems when they worked at home or while traveling on business. Northwest Industries employed a key escrow system to manage the encryption keys; Jason had tested and verified that it worked as planned. The CISO had used the Privacy Management Framework to develop procedures to protect personal information collected from customers. Jason verified that employees received detailed training on how to handle such information when initially hired and attended mandatory "refresher" courses every six months. Multifactor authentication was used to control access to the company's databases. Jason also verified that Northwest Industries digitally signed transactions with its business partners and required customers to digitally sign all orders that exceeded \$10,000. It was also beginning to explore how to use blockchain technology to further improve its business processes.

Based on his report, Jason's supervisor and the CIO were satisfied with Northwest Industries' measures to protect confidentiality and privacy. They asked Jason next to examine the controls in place to achieve the remaining two principles of systems reliability in the AICPA's Trust Services Framework: processing integrity and availability.

KEY TERMS

information rights
management (IRM) 379
data loss prevention (DLP) 379
digital watermark 379
data masking 379
tokenization 379
opt-in 381

opt-out 381
cookie 382
identity theft 383
encryption 384
plaintext 384
ciphertext 384
decryption 384

symmetric encryption
systems 387
asymmetric encryption
systems 387
public key 387
private key 387
key escrow 388

virtual private network
(VPN) 388
nonrepudiation 389
hashing 390

hash 390
digital signature 390
digital certificate 392
certificate authority 392

public key infrastructure
(PKI) 392
blockchain 392
nonce 393

AIS in Action

CHAPTER QUIZ

- Which of the following statements is true?
 - Encryption is sufficient to protect confidentiality and privacy.
 - Cookies are text files that only store information. They cannot perform any actions.
 - The controls for protecting confidentiality are not effective for protecting privacy.
 - All of the above are true.
- A digital signature is created by hashing a document and then encrypting the hash with the signer's _____.
 - private key
 - public key
 - symmetric key
 - None of the above
- Able wants to send a file to Baker over the Internet and protect the file so that only Baker can read it and verify that it came from Able. What should Able do?
 - Encrypt the file using Able's public key, and then encrypt it again using Baker's private key.
 - Encrypt the file using Able's private key, and then encrypt it again using Baker's private key.
 - Encrypt the file using Able's public key, and then encrypt it again using Baker's public key.
 - Encrypt the file using Able's private key, and then encrypt it again using Baker's public key.
- Which of the following statements is true?
 - Encryption and hashing are both reversible (can be decoded).
 - Encryption is reversible, but hashing is not.
 - Hashing is reversible, but encryption is not.
 - Neither hashing nor encryption is reversible.
- Confidentiality focuses on protecting _____.
 - personal information collected from customers
 - a company's annual report stored on its website
 - merger and acquisition plans
 - All of the above
- Which of the following statements about obtaining consent to collect and use a customer's personal information is true?
 - The default policy in Europe is opt-out, but in the United States the default is opt-in.
 - The default policy in Europe is opt-in, but in the United States the default is opt-out.
 - The default policy in both Europe and the United States is opt-in.
 - The default policy in both Europe and the United States is opt-out.
- One of the Privacy Management Framework principles is security. According to the framework, what is the nature of the relationship between privacy and security?
 - Privacy management framework is a necessary, but not sufficient, precondition to effective security.
 - Privacy management framework is both necessary and sufficient to effective security.
 - Security is a necessary, but not sufficient, precondition to protect privacy.
 - Security is both necessary and sufficient to protect privacy.

8. Which of the following statements is true?
 - a. Symmetric encryption is faster than asymmetric encryption and can be used to provide nonrepudiation of contracts.
 - b. Symmetric encryption is faster than asymmetric encryption but cannot be used to provide nonrepudiation of contracts.
 - c. Asymmetric encryption is faster than symmetric encryption and can be used to provide nonrepudiation of contracts.
 - d. Asymmetric encryption is faster than symmetric encryption but cannot be used to provide nonrepudiation of contracts.
9. Which of the following statements is true?
 - a. VPNs protect the confidentiality of information while it is in transit over the Internet.
 - b. Encryption limits firewalls' ability to filter traffic.
 - c. A digital certificate contains that entity's public key.
 - d. All of the above are true.
10. Which of the following can organizations use to protect the privacy of a customer's personal information when giving programmers a realistic data set with which to test a new application?
 - a. digital signature
 - b. digital watermark
 - c. data loss prevention
 - d. data masking

DISCUSSION QUESTIONS

- 12.1 From the viewpoint of the customer, what are the advantages and disadvantages to the opt-in versus the opt-out approaches to collecting personal information? From the viewpoint of the organization desiring to collect such information?
- 12.2 In both the EU and in the United States organizations have been fined millions of dollars for violating provisions of the GDPR and the CCPA privacy regulations. Some critics, however, argue that fines alone are insufficient to improve privacy protections because many organizations view regulatory fines as a "cost of doing business," and the fines do not personally affect any individual in those organizations. Therefore, some privacy advocates argue that the only way that privacy regulations like the GDPR and CCPA will successfully change organizational behavior is if they are modeled after the Sarbanes–Oxley (SOX) Act to include jail time for executives of organizations that violate those regulations. What do you think? Why?
- 12.3 The GDPR gives people the right to request that organizations delete their personal data. What are some of the technical issues that make this difficult to do?
- 12.4 What privacy concerns might arise from the use of biometric authentication techniques? What about the embedding of radio frequency identification (RFID) tags in products such as clothing? What other technologies might create privacy concerns?
- 12.5 Online proctoring tools seek to prevent and detect cheating on exams. However, critics argue that such tools invade the privacy of students. What do you think: Should teachers use software to proctor online tests? Why (not)?
- 12.6 Encryption protects the confidentiality and privacy of sensitive information that is stored digitally. In what situations, if any, would storing sensitive information only on paper be an alternative to encryption?

PROBLEMS

12.1 Match the terms with their definitions:

- | | | |
|-------|---|---|
| _____ | 1. virtual private network (VPN) | a. Random number used to validate a new block in a blockchain |
| _____ | 2. data loss prevention (DLP) | b. A hash encrypted with the creator's private key |
| _____ | 3. digital signature | c. Company that issues pairs of public and private keys and verifies the identity of the owner of those keys |
| _____ | 4. digital certificate | d. Secret mark used to identify proprietary information |
| _____ | 5. data masking | e. Encrypted tunnel used to transmit information securely across the Internet |
| _____ | 6. symmetric encryption | f. Replacing real data with fake data |
| _____ | 7. blockchain | g. Unauthorized use of facts about another person to commit fraud or other crimes |
| _____ | 8. plaintext | h. Distributed ledger of hashed documents |
| _____ | 9. hashing | i. Process of turning ciphertext into plaintext |
| _____ | 10. ciphertext | j. Document or file that can be read by anyone who accesses it |
| _____ | 11. information rights management (IRM) | k. Used to store an entity's public key, often found on websites |
| _____ | 12. certificate authority | l. Procedure to filter outgoing traffic to prevent confidential information from leaving |
| _____ | 13. nonrepudiation | m. Process that transforms a document or file into a fixed-length string of data |
| _____ | 14. digital watermark | n. Document or file that must be decrypted to be read |
| _____ | 15. asymmetric encryption | o. Copy of an encryption key stored securely to enable decryption if the original encryption key becomes unavailable |
| _____ | 16. key escrow | p. Encryption process that uses a pair of matched keys, one public and the other private; either key can encrypt something, but only the other key in that pair can decrypt |
| _____ | 17. nonce | q. Encryption process that uses the same key to both encrypt and decrypt |
| | | r. Inability to unilaterally deny having created a document or file or having agreed to perform a transaction |
| | | s. Software that limits what actions (read, copy, print, etc.) can be performed by users granted access to a file or document |

12.2 Cost-effective controls to provide confidentiality require valuing the information to be protected. This involves classifying information into discrete categories. Propose a minimal classification scheme that could be used by any business, and provide examples of the type of information that would fall into each of those categories.

12.3 Download a hash calculator from the course website (or use one provided by your instructor) or use an online hash calculator for this exercise. Use it to create SHA-256 (or any other hash algorithm your instructor assigns) hashes for the following:

- a. A document that contains this text: "I will pay you \$10.39 to walk the dog."
- b. A document that contains this text: "I will pay you \$1039 to walk the dog."

- c. A document that contains this text: “I will pay you \$10.39 to walk the Dog.”
- d. A document that contains this text: “I will pay you \$10.39 to walk the dog.” (Note: this message contains two spaces between the words “to” and “walk”).
- e. Make a copy of the document used in step a, and calculate its hash value.
- f. What do the results of steps a–d show?
- g. What does comparing the hash from step a to the hash from step e tell you?

- 12.4** Accountants often need to print financial statements with the words “DO NOT COPY” appearing in light type in the background.
- a. Create a watermark with the phrase “DO NOT COPY” in a Word document. Print out a document that displays that watermark.
 - b. Create the same watermark in Excel, and print out a spreadsheet page that displays that watermark.
 - c. Can you make your watermark “invisible” so that it can be used to detect whether a document containing sensitive information has been copied to an unauthorized location? How? How could you use that “invisible” watermark to detect violation of copying policy?
- 12.5** Create a spreadsheet to compare current monthly mortgage payments versus the new monthly payments if the loan were refinanced, as shown:

Refinancing Calculator	
Instructions: Only Enter Data into Borderless Cells; Do Not Enter Data into Cells with Borders	
Current loan amount	\$500,000
Current term (years)	30
Current interest rate	5%
Current monthly payment	\$2,684.11
New loan amount	\$400,000
New loan term (years)	25
New interest rate	4.50%
New monthly payment	\$2,223.33

REQUIRED

- a. Restrict access to the spreadsheet by encrypting it.
- b. Further protect the spreadsheet by limiting users to the ability to select and enter data only in the six highlighted cells.

Hint: The article “Keeping Secrets: How to Protect Your Computer from Snoops and Spies,” by Theo Callahan in the July 2007 issue of the *Journal of Accountancy*, explains how to do this using Excel 2003. Review the article, and then use Excel’s built-in help function to learn how to do this with later versions of Excel.¹

- 12.6** Practice encryption using either the encryption capabilities provided by your computer’s operating system or third-party encryption software.

REQUIRED

- a. Encrypt a file and save it. Create another user account on your computer, and log in as that user. Which of the following actions can you perform?
 1. Open the file.
 2. Copy the file to a USB drive.
 3. Move the file to a USB drive.
 4. Rename the file.
 5. Delete the file.

¹Lifelong learning opportunity: see the Excel Homework Problems section in the Preface.

- b. Send the encrypted file to your instructor.
- c. Obtain an encrypted file from your instructor. Which of the following actions can you perform?
 - 1. Open the file.
 - 2. Copy the file to a USB drive.
 - 3. Move the file to a USB drive.
 - 4. Rename the file.
- d. Import the decryption key to the file you received from your instructor and print out the contents of that file.

12.7 Explore and test various browser privacy settings.

- a. Go to www.cisecurity.org and obtain the recommended best practices for privacy settings for your browser. Change your existing settings to those best practices and then use your browser to perform these tasks: (1) search for information about identity theft protection products, (2) open and read your personal e-mail account, (3) open and read your university or work-related e-mail account, (4) attempt to purchase something from amazon.com or any other site (you need not actually make the purchase, just try to at least get to the point in the shopping cart where you are asked to enter your credit card number), (5) log in to your favorite social networking site, and (6) play an online game such as Sudoku. What was the effect, if any, of changing your privacy settings?
- b. Repeat step a above for another browser. Which browser makes it easier to configure privacy settings? Are there any differences between the browsers in terms of using them after you have changed the privacy settings to those recommended by the cisecurity.org benchmark documents?

12.8 Explore the power of the bcc feature to protect privacy.

- a. Write a message and send it to yourself plus use the cc feature to send it to a set of people, including one of your other e-mail accounts in the cc list.
- b. Repeat step a, but this time send the e-mail only to yourself and then list everyone in the bcc field.
- c. Use your other e-mail account (the one you included in the cc and bcc fields) to open the two e-mail messages. Use all available options (e.g., view full header, etc.) to see what you can learn about the recipient lists for both e-mails. What is the power of the bcc field?

12.9 Answer all of the following multiple-choice questions:

- 1. Websites often provide a link to the organization's privacy policy. Doing so most directly satisfies the requirements of the section of the Privacy Management Framework referred to as
 - a. management.
 - b. notice.
 - c. quality.
 - d. collection.
- 2. Which of the following factors increase the strength of an encryption solution?
 - a. Securely storing encryption keys somewhere other than in the browser
 - b. Keeping the encryption algorithm secret
 - c. Using a 24-bit encryption key
 - d. All three options increase the strength of an encryption solution.
 - e. None of the three factors increase the strength of an encryption solution.
- 3. Able wants to send an encrypted document to Baker as an e-mail attachment. If Able wants to securely send Baker the key to decrypt the document, Able should encrypt the key using
 - a. Able's public asymmetric key.
 - b. Able's private asymmetric key.
 - c. Baker's public asymmetric key.
 - d. Baker's private asymmetric key.

4. Which of the following is the MOST important reason why it is virtually impossible for one entity in a blockchain network to unilaterally alter a document after it has been recorded and validated in a new block of transactions?
 - a. The use of a nonce to validate each block
 - b. The existence of multiple copies of the blockchain on many different computers
 - c. Digital signatures
 - d. Digital certificate
5. The Privacy Management Framework stresses the importance of obtaining consent when collecting, using, and sharing information about customers. If a company's policy is to ask customers for permission to collect sensitive personal information and then only asks questions about sensitive matters (such as political beliefs or sexual orientation) after the customer agrees to answer such questions, it is following the process referred to as
 - a. explicit consent (opt-out).
 - b. explicit consent (opt-in).
 - c. implicit consent (opt-out).
 - d. implicit consent (opt-in).
6. Which of the following statements is true?
 - a. A file encrypted with X's private key can only be decrypted by using X's private key.
 - b. A file encrypted with X's private key can only be decrypted using X's public key.
 - c. A file encrypted with X's private key can only be decrypted by using Y's private key.
 - d. A file encrypted with X's private key can only be decrypted using Y's public key.
7. To decrypt a digital signature, the recipient uses the
 - a. sender's private key.
 - b. sender's public key.
 - c. recipient's private key.
 - d. recipient's public key.
8. When is encryption LEAST effective in protecting the confidentiality of sensitive data?
 - a. At rest
 - b. While it is being processed
 - c. While it is transmitted over the Internet
 - d. Encryption is equally effective in protecting confidentiality at all stages of the data processing cycle.
9. Which of the following is the most reliable way to acquire a company's public asymmetric key to be confident it really is owned by that company?
 - a. Obtain it from a digital signature posted on that company's website.
 - b. Obtain it directly from the company by means of an encrypted e-mail.
 - c. Obtain it from a valid digital certificate issued by a trusted certificate authority and posted on the company's website.
 - d. Obtain it directly from the company via a USB delivered by a trusted delivery service (e.g., FedEx, UPS, or DHL).
10. The system used to issue pairs of asymmetric encryption keys and digital certificates is called
 - a. a VPN.
 - b. key escrow.
 - c. a PKI.
 - d. tokenization or data masking.

Case 12-1 Protecting Privacy of Tax Returns

The department of taxation in your state is developing a new computer system for processing individual and corporate income-tax returns. The new system features direct data input and inquiry capabilities. Taxpayers are identified by Social Security number (for individuals) and federal tax identification number (for corporations). The new system should be fully implemented in time for the next tax season.

The new system will serve three primary purposes:

1. Tax return data will automatically input into the system either directly (if the taxpayer files electronically) or by a clerk at central headquarters scanning a paper return received in the mail.
2. The returns will be processed using the main computer facilities at central headquarters. Processing will include four steps:
 - a. Verifying mathematical accuracy
 - b. Auditing the reasonableness of deductions, tax due, and so on, through the use of edit routines, which also include a comparison of current and prior years' data
 - c. Identifying returns that should be considered for audit by department revenue agents
 - d. Issuing refund checks to taxpayers

3. Inquiry services. A taxpayer will be allowed to determine the status of their return or get information from the last 3 years' returns by calling or visiting one of the department's regional offices or by accessing the department's website and entering their social security number.

The state commissioner of taxation and the state attorney general are concerned about protecting the privacy of personal information submitted by taxpayers. They want to have potential problems identified before the system is fully developed and implemented so that the proper controls can be incorporated into the new system.

REQUIRED

Describe the potential privacy problems that could arise in each of the following three areas of processing, and recommend the corrective action(s) to solve each problem identified:

- a. data input
- b. processing of returns
- c. data inquiry (*CMA Examination, adapted*)

Case 12-2 Blockchain

Blockchain is used by many companies, including accounting firms. Select a company (or choose one identified by your professor), and research how it uses

blockchain. Write a brief report summarizing how that company is using blockchain, and explain the benefits it provides.

AIS in Action Solutions

QUIZ KEY

1. Which of the following statements is true?
 - a. Encryption is sufficient to protect confidentiality and privacy. [Incorrect. Encryption is not sufficient because sensitive information cannot be encrypted at all times; it must be decrypted during processing, when displayed on a monitor, or included in a printed report.]
 - ▶ b. Cookies are text files that only store information. They cannot perform any actions. [Correct. Cookies are text files, not executable programs. They can, however, store sensitive information, so they should be protected.]

- c. The controls for protecting confidentiality are not effective for protecting privacy. [Incorrect. The same set of controls—encryption, access controls, and training—can be used to protect both confidentiality and privacy.]
 - d. All of the above are true. [Incorrect. Statements a and c are false.]
2. A digital signature is created by hashing a document and then encrypting the hash with the signer's _____.
- ▶ a. private key [Correct. Creating a hash provides a way to verify the integrity of a document, and encrypting it with the signer's private key provides a way to prove that the sender created the document.]
 - b. public key [Incorrect. Anyone could encrypt something with the signer's public key. Therefore, this process cannot be used to prove who created a document.]
 - c. symmetric key [Incorrect. A symmetric key is possessed by more than one party, so encrypting something with it does not provide a means to prove who created a document.]
 - d. None of the above [Incorrect. Only choices b and c are incorrect; choice a is correct.]
3. Able wants to send a file to Baker over the Internet and protect the file so that only Baker can read it and verify that it came from Able. What should Able do?
- a. Encrypt the file using Able's public key, and then encrypt it again using Baker's private key. [Incorrect. Able does not know Baker's private key.]
 - b. Encrypt the file using Able's private key, and then encrypt it again using Baker's private key. [Incorrect. Able does not know Baker's private key.]
 - c. Encrypt the file using Able's public key, and then encrypt it again using Baker's public key. [Incorrect. Baker does not know Able's private key and therefore cannot decrypt the file encrypted with Able's public key.]
 - ▶ d. Encrypt the file using Able's private key, and then encrypt it again using Baker's public key. [Correct. Encrypting it with Baker's public key means that only Baker can decrypt it. Then, Baker can use Able's public key to decrypt the file—if the result is understandable, it had to have been created by Able and encrypted with Able's private key.]
4. Which of the following statements is true?
- a. Encryption and hashing are both reversible (can be decoded). [Incorrect. Hashing is irreversible.]
 - ▶ b. Encryption is reversible, but hashing is not. [Correct. Encryption can be reversed to decrypt the ciphertext, but hashing cannot be reversed.]
 - c. Hashing is reversible, but encryption is not. [Incorrect. Hashing is irreversible, but encryption is reversible.]
 - d. Neither hashing nor encryption is reversible. [Incorrect. Encryption is reversible, a process called decryption.]
5. Confidentiality focuses on protecting _____.
- a. personal information collected from customers [Incorrect. Protecting customers' personal information relates to the principle of privacy.]
 - b. a company's annual report stored on its website [Incorrect. A company's annual report is meant to be available to the public.]
 - ▶ c. merger and acquisition plans [Correct. Merger and acquisition plans are sensitive information that should not be made public until the deal is consummated.]
 - d. All of the above [Incorrect. Statements a and b are false.]
6. Which of the following statements about obtaining consent to collect and use a customer's personal information is true?
- a. The default policy in Europe is opt-out, but in the United States the default is opt-in. [Incorrect. The default policy in Europe is opt-in, and in the United States it is opt-out.]
 - ▶ b. The default policy in Europe is opt-in, but in the United States the default is opt-out. [Correct.]

- c. The default policy in both Europe and the United States is opt-in. [Incorrect. The default policy in Europe is opt-in, and in the United States it is opt-out.]
 - d. The default policy in both Europe and the United States is opt-out. [Incorrect. The default policy in Europe is opt-in, and in the United States it is opt-out.]
7. One of the Privacy Management Framework principles is security. According to the framework, what is the nature of the relationship between privacy and security?
- a. Privacy is a necessary, but not sufficient, precondition to effective security. [Incorrect. Security is one of the criteria in the Privacy Management Framework because you need security in order to have privacy. Security alone, however, is not enough; that is why there are eight other criteria in the framework.]
 - b. Privacy is both necessary and sufficient to effective security. [Incorrect. Security is one of the criteria in the Privacy Management Framework because you need security in order to have privacy. Security alone, however, is not enough; that is why there are eight other criteria in the framework.]
 - ▶ c. Security is a necessary, but not sufficient, precondition to protect privacy. [Correct. Security is one of the criteria in the Privacy Management Framework because you need security in order to have privacy. Security alone, however, is not enough; that is why there are eight other criteria in the framework.]
 - d. Security is both necessary and sufficient to protect privacy. [Incorrect. Security is one of the criteria in the Privacy Management Framework because you need security in order to have privacy. Security alone, however, is not enough; that is why there are eight other criteria in the framework.]
8. Which of the following statements is true?
- a. Symmetric encryption is faster than asymmetric encryption and can be used to provide nonrepudiation of contracts. [Incorrect. Symmetric encryption cannot be used for nonrepudiation because both parties share the key, so there is no way to prove who created and encrypted a document.]
 - ▶ b. Symmetric encryption is faster than asymmetric encryption but cannot be used to provide nonrepudiation of contracts. [Correct. Symmetric encryption is faster than asymmetric encryption, but it cannot be used for nonrepudiation; the key is shared by both parties, so there is no way to prove who created and encrypted a document.]
 - c. Asymmetric encryption is faster than symmetric encryption and can be used to provide nonrepudiation of contracts. [Incorrect. Symmetric encryption is faster than asymmetric encryption.]
 - d. Asymmetric encryption is faster than symmetric encryption but cannot be used to provide nonrepudiation of contracts. [Incorrect. Symmetric encryption is faster than asymmetric encryption. Also, asymmetric encryption can be used to provide nonrepudiation because encrypting a contract with the creator's private key proves that the encrypter did indeed create the contract.]
9. Which of the following statements is true?
- a. VPNs protect the confidentiality of information while it is in transit over the Internet. [Incorrect. This statement is true, but so are the others.]
 - b. Encryption limits firewalls' ability to filter traffic. [Incorrect. This statement is true—firewalls cannot apply their rules to encrypted packets—but so are the others.]
 - c. A digital certificate contains that entity's public key. [Incorrect. This statement is true, but so are the others.]
 - ▶ d. All of the above are true. [Correct. All three statements are true.]

10. Which of the following can organizations use to protect the privacy of a customer's personal information when giving programmers a realistic data set with which to test a new application?
- a. digital signature [Incorrect. A digital signature is used for nonrepudiation. However, because it is an encrypted hash, it cannot be used to test programming logic.]
 - b. digital watermark [Incorrect. A digital watermark is used to identify proprietary data, but it does not protect privacy.]
 - c. data loss prevention [Incorrect. Data loss prevention is designed to protect confidentiality by filtering outgoing messages to prevent sensitive data from leaving the company.]
 - ▶ d. data masking [Correct. Masking replaces actual values with fake ones, but the result is still the same type of data, which can then be used to test program logic.]